

PROJECT 01 · EMAIL SECURITY
EMAIL THREAT INVESTIGATION & ANALYSIS

Report By: Shravani Joshi

EXECUTIVE SUMMARY

A total of 13 emails were analyzed to determine whether they were legitimate, medium risk or suspicious by examining their email headers, authentication results (SPF, DKIM, DMARC), sender details, attachments, embedded links, and email content.

Overall Findings

- Total Emails Analyzed: 13
- Safe Emails: 5
- Medium Risk Emails: 2
- Suspicious Emails: 6

Key Observations

- Legitimate emails passed SPF, DKIM, and DMARC authentication and had trusted domains.
- Medium-risk emails contained suspicious requests, such as changing payment details or requesting sensitive documents, but lacked sufficient evidence to confirm malicious intent without further verification.
- Malicious emails used various social engineering techniques, including:
 - Urgency and time pressure
 - Authority impersonation (CEO, Microsoft, IT Support)
 - Fear of account suspension or security compromise
 - Financial incentives and lottery scams
 - Invoice and payment fraud

Common Indicators of Compromise

- Failed or missing SPF, DKIM, and DMARC authentication.
- Use of lookalike or deceptive domains.
- Mismatched Reply-To addresses.
- Emails sent from unknown or public mail servers.
- Lack of TLS encryption in several malicious emails.

Potential Risks Identified

- Credential theft through phishing websites.
- Business Email Compromise (BEC) and CEO impersonation.
- Financial fraud through fake invoices and gift card scams.
- Malware infection through malicious attachments.
- Identity theft through collection of personal information.

Recommendations

- Verify unexpected financial or account-related requests through trusted communication channels before taking action.
- Avoid opening suspicious attachments, especially macro-enabled documents and ZIP files.
- Never click links from untrusted or unexpected emails; access services through official websites instead.
- Check sender addresses, Reply-To fields, and authentication results before responding.
- Report suspicious emails to the Information Security or SOC team immediately.
- Continue regular security awareness training to help employees recognize phishing and social engineering attacks.

The investigation demonstrates that while many phishing emails can be identified through technical indicators such as failed authentication and suspicious domains, some attacks may appear technically legitimate. Therefore, effective email security requires both technical verification and careful analysis of the email's context, sender behaviour, and requested actions before responding or acting on any request.

EMAIL BY EMAIL ANALYSIS

1. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

Password Expiry Reminder – Action Needed Within 5 Days

Field	Analysis
Classification	SAFE
Sender	ithelpdesk@solvexindustries.com
Reply-To	Matches sender
Return-Path	Matches sender
DKIM	Pass
DMARC	Pass
Encryption	TLS 1.3
Attachments	-
URLs	-
IOCs	-
Social Engineering	Low urgency (routine password expiry reminder)
Recommended Action	Safe to follow. Access the internal IT Service Portal through official channels to update the password.

2. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

URGENT: Your Mailbox Storage is FULL – Verify Now to Avoid Suspension

Field	Analysis
Classification	SUSPICIOUS (Credential Phishing)
Sender	support@solvex-industries-helpdesk.com
Reply-To	recovery-team@mail-secure-verify.net (mismatch)
Return-Path	bounce@mail-secure-verify.net
SPF	Fail
DKIM	Fail
DMARC	Fail
Encryption	None
Attachments	-
URLs	hxxp://solvex-industries-helpdesk.verify-account-secure.com/mailbox/confirm?user=aditya.rao
IOCs	Lookalike sender domain, different Reply-To and Return-Path domain, external IP and hostname
Social Engineering	Urgency, fear, authority impersonation, account suspension threat, data loss threat, time pressure
Potential Impact	If the recipient clicks the embedded link and enters their login credentials, the attacker could steal the user's account credentials and gain unauthorized access to the corporate mailbox. This may lead to account compromise, unauthorized access to sensitive emails and documents, data theft, etc.
Recommended Action	Do not click the link or submit credentials. Report the email, block the sender and URL and reset credentials if compromised.

IOCs

IOC Type	Indicator	Reason
Domain	solvex-industries-helpdesk.com	Lookalike domain impersonating the legitimate organization.
Domain	mail-secure-verify.net	Used in Reply-To and Return-Path to redirect responses to

		attacker-controlled infrastructure.
Bcc Distribution	allstaff-list223@solvex-industries-helpdesk.com	Indicates the email was distributed through a bulk mailing list, suggesting a mass phishing campaign.
URL	hxxp://solvex-industries-helpdesk.verify-account-secure.com/mailbox/confirm?user=aditya.rao	Credential phishing URL using a deceptive subdomain.
IP Address	193.41.77.108	Suspicious external sending IP not associated with the organization's mail infrastructure.
Hostname	unknown-host-193.41.77.108.static-cloud.ru	Suspicious external hostname inconsistent with legitimate corporate infrastructure.

3. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

Invoice SI-4471 & Updated Bank Details for Future Payments

Field	Analysis
Classification	MEDIUM RISK
Sender	ramesh.kulkarni@apex-steeltraders.co
Reply-To	accounts.payments@apexsteel-billing.com (domain mismatch)
Return-Path	Matches sender
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption	TLS 1.2
Attachments	Invoice SI-4471 Apex Steel.pdf
URLs	-
IOCs	Reply-To domain: apexsteel-billing.com (does not match sender domain and may redirect communication); Payment redirection request: asks recipient to use a new bank account instead of the previously shared account (common BEC indicator).
Social Engineering	Authority, urgency, financial pressure, trust exploitation
Potential Impact	If the recipient opens the attached invoice and processes the payment without independently verifying the requested bank account change, the payment may be transferred to an attacker-controlled account instead of the legitimate vendor. This could result in financial loss, disruption of business operations, delayed payments to the genuine supplier, and potential legal or reputational consequences.
Recommended Action	Verify the bank account change through a trusted, previously known contact before processing payment. Review the attached invoice for altered payment details.

4. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

Revised Leave & Work-From-Home Policy – Effective 15 July 2026

Field	Analysis
Classification	SAFE
Sender	hr@solvexindustries.com

Reply-To	Matches sender
Return-Path	Matches sender
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption	TLS 1.3
Attachments	-
URLs	-
IOCs	-
Social Engineering	None (routine organizational communication)
Recommended Action	Safe to access the HR portal through official company channels to review the updated policy.

5. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

Confidential – Immediate Wire Transfer Required (Time Sensitive)

Field	Analysis
Classification	SUSPICIOUS
Sender	rajeev.malhotra.md@gmail-corpmail.com
Reply-To	Matches sender (rajeev.malhotra.md@gmail-corpmail.com)
Return-Path	Matches sender
SPF	None (No SPF record)
DKIM	None
DMARC	None
Encryption	None
Attachments	-
URLs	-
IOCs	Lookalike domain, external IP address, no SPF, DKIM or DMARC records
Social Engineering	Authority impersonation, urgency, secrecy, financial pressure, executive impersonation, isolation, time pressure
Potential Impact	If the recipient acts on the request, they may transfer USD 18,500 to an attacker-controlled bank account once the fraudulent banking details are provided. This could result in financial loss, bypassing of organizational approval procedures, and reputational damage.
Recommended Action	Do not initiate the wire transfer. Verify the request directly with the Managing Director using a trusted communication channel such as a phone call or official corporate email. Follow established financial approval procedures and report the email to the Security and Finance teams.

IOCs

IOC Type	Indicator	Reason
Domain	gmail-corpmail.com	Lookalike domain impersonating a legitimate corporate email service instead of using the organization's official domain.
Email Address	rajeev.malhotra.md@gmail-corpmail.com	Attempts to impersonate the Managing Director using a deceptive email address.
IP Address	45.137.22.9 (Netherlands)	External sending IP associated with a third-party mail relay rather than the organization's mail infrastructure.

Hostname	smtp-relay-88.freemailhost.io	Email originated from a public mail relay instead of the company's official mail server.
Authentication	No SPF, DKIM, or DMARC records	Lack of standard email authentication makes sender identity unverifiable and increases the likelihood of spoofing.

6. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

'Q1_Vendor_Compliance_Report.xlsx' has been shared with you

Field	Analysis
Classification	SAFE
Sender	drive-shares-noreply@google.com
Reply-To	Matches sender
Return-Path	Matches sender
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption	Yes (TLS 1.3)
Attachments	-
URLs	https://docs.google.com/spreadsheets/d/1kQ3z-example-fileid-9f2/edit?usp=sharing
IOCs	None
Social Engineering	None
Recommended Action	Safe to access the shared file if the sharing request is expected.

7. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

Unusual sign-in activity detected on your Microsoft account

Field	Analysis
Classification	SUSPICIOUS (Credential Phishing)
Sender	security-noreply@microsoft-online.com
Reply-To	no-reply@microsoft-online.com
Return-Path	bounce@microsoft-online.com
SPF	Fail
DKIM	Fail
DMARC	Fail
Encryption	None
Attachments	-
URLs	https://login.microsoft-online.com/secure/verify-identity?ref=aditya.rao
IOCs	microsoft-online.com, IP address, failed SPF, DKIM, DMARC, phishing URL
Social Engineering	Fear, urgency, authority impersonation, account compromise warning, time pressure
Potential Impact	If the recipient clicks the link and enters their Microsoft credentials, the attacker could gain unauthorized access to the user's Microsoft account, including Outlook, OneDrive, and Teams. This may lead to credential theft, data exfiltration and further compromise of organizational resources.
Recommended Action	Do not click the link or enter any credentials. Verify account activity by signing in directly through the official Microsoft portal or using the Microsoft Authenticator app. Report the email to the Security team and immediately change the password if credentials were entered.

IOCs

IOC Type	Indicator	Reason
Domain	microsoft-online.com	Typosquatted domain replacing the letter 'o' with the digit '0' to impersonate Microsoft's official domain.
Email Address	security-noreply@microsoft-online.com	Uses the deceptive domain to impersonate Microsoft's security notification service.
URL	hxxp://login.microsoft-online.com/secure/verify-identity?ref=aditya.rao	Credential harvesting URL hosted on the typosquatted domain instead of the legitimate login.microsoftonline.com or microsoft.com domains.
IP Address	77.91.134.6	External IP address associated with the email source rather than Microsoft's mail infrastructure.
Hostname	host-77-91-134-6.vpn-exit.net	Originates from a VPN exit node, which is inconsistent with legitimate Microsoft email servers and can be used to conceal the attacker's identity.
Authentication	SPF: Fail, DKIM: Fail, DMARC: Fail	All email authentication mechanisms failed, indicating the sender could not be verified and increasing the likelihood of spoofing or phishing.

8. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

Exciting Career Opportunity – Senior Finance Role (Immediate Response Needed)

Field	Analysis
Classification	MEDIUM RISK (Suspicious Recruitment Email)
Sender	neha.kapoor.hr@talentbridge-recruiters.net
Reply-To	Matches sender
Return-Path	Matches sender
SPF	Pass
DKIM	Pass
DMARC	None (No policy published)
Encryption	TLS 1.2
Attachments	JD_SeniorFinanceManager_Client.zip
URLs	-
IOCs	Compressed ZIP attachment, request for sensitive personal documents (PAN card and salary slip), unusually attractive job offer with immediate response requested
Social Engineering	Curiosity, urgency, financial incentive, trust exploitation
Potential Impact	Opening the ZIP attachment could expose the recipient to malicious files or malware if the archive contains executable content. Sending the requested PAN card and salary slip could result in identity theft, financial fraud, or misuse of personal information.
Recommended Action	Do not open the ZIP attachment or share personal documents until the recruiter and organization have been independently verified. Confirm the legitimacy of the recruiter through the company's official website or trusted contact channels before responding.

9. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

Your TallyPrime Cloud Subscription Renewal Invoice – INV-88213

Field	Analysis
Classification	SAFE
Sender	billing@tallysolutions.com
Reply-To	Matches sender
Return-Path	Matches sender
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption	TLS 1.3
Attachments	INV-88213 TallyPrime Renewal.pdf
URLs	-
IOCs	None identified
Social Engineering	None
Recommended Action	Safe to review the attached invoice and process the renewal through the official Tally Customer Portal or the organization's existing payment process. Verify invoice details against internal purchase records if required.

10. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

CONGRATULATIONS!!! YOU HAVE WON USD 1,000,000 IN THE INTERNATIONAL EMAIL LOTTERY

Field	Analysis
Classification	SUSPICIOUS (Lottery Scam)
Sender	claims.department009@yandex-mailer.com
Reply-To	agent.williams.claims@outlook-verify.info
Return-Path	claims.department009@yandex-mailer.com
SPF	Fail
DKIM	Fail
DMARC	Fail
Encryption	None
Attachments	-
URLs	hxxp://claim-your-prize-now.lottery-verify.info/claim?ref=44921
IOCs	yandex-mailer.com, outlook-verify.info, lottery-verify.info, 185.220.101.44, unknown-relay-node4.freehosting-mail.com
Social Engineering	Greed, urgency, advance fee fraud, time pressure
Potential Impact	If the recipient responds or clicks the embedded link, they may disclose personal and financial information, become a victim of identity theft, or lose money through fraudulent processing or courier fees.
Recommended Action	Do not click the link, reply to the email, or provide any personal or financial information. Report the email to the Security team, block the sender and associated domains, and delete the email.

IOCs

IOC Type	Indicator	Reason
Domain	yandex-mailer.com	Unrelated third-party domain impersonating an official lottery organization.
Domain	outlook-verify.info	Reply-To domain is unrelated to the sender.

Domain	lottery-verify.info	Suspicious domain used to host the prize claim page instead of an official lottery website.
Hostname	unknown-relay-node4.freehosting-mail.com	Email originated from a free hosting mail relay instead of an official mail server.
Authentication	SPF: Fail, DKIM: Fail, DMARC: Fail	All authentication mechanisms failed, indicating the sender's identity could not be verified.

11. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

Quick request before my flight

Field	Analysis
Classification	SUSPICIOUS
Sender	suresh.iyer@solvexindustries.com
Reply-To	s.iyer.cfo.travel@outlook.com
Return-Path	suresh.iyer@solvexindustries.com
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption	TLS 1.3
Attachments	-
URLs	-
IOCs	s.iyer.cfo.travel@outlook.com, Reply-To mismatch, request for Amazon gift card codes, request to bypass verbal verification
Social Engineering	Authority impersonation, urgency, isolation, financial manipulation, pretexting
Potential Impact	If the recipient purchases and shares the Amazon gift card codes, the attacker can immediately redeem them, resulting in financial loss.
Recommended Action	Do not purchase or share gift card codes. Verify the request directly with using a trusted communication channel such as a phone call or in-person confirmation. Report the email to the Security team and follow the organization's financial approval procedures. Check what else was sent using this mail and reset credentials.

IOCs

IOC Type	Indicator	Reason
Reply-To Email	s.iyer.cfo.travel@outlook.com	Uses a personal Outlook account instead of the official corporate domain.
Reply-To Mismatch	outlook.com	Reply-To domain differs from the sender's corporate domain despite SPF, DKIM, and DMARC passing.
Request	Purchase 5 Amazon gift cards worth Rs. 5,000 each	Requests payment through gift cards instead of approved corporate payment methods, which is a common indicator of fraud.
Request	"Don't call the office... email is easier"	Attempts to prevent independent verification.

12. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

Reminder: Mandatory Security Awareness Training – Due This Friday

Field	Analysis
Classification	SAFE
Sender	infosec@solvexindustries.com

Reply-To	Matches sender
Return-Path	Matches sender
SPF	Pass
DKIM	Pass
DMARC	Pass
Encryption	TLS 1.3
Attachments	-
URLs	learn.solvexindustries.com
IOCs	None identified
Social Engineering	None
Recommended Action	Safe to access the internal learning portal using the official URL and complete the mandatory training.

13. RECOVERED MAILBOX EVIDENCE — CASE FILE CA-ETI-01

Pending Invoice – Please Review & Process on Priority

Field	Analysis
Classification	SUSPICIOUS
Sender	accounts.receivable@shreeganesh-logistics.in
Reply-To	Matches sender
Return-Path	mailer@shreeganesh-logistics.in
SPF	Fail (domain not authorized to send)
DKIM	None
DMARC	Fail
Encryption	None
Attachments	Pending_Invoice_Challan_Details.docm (Macro-Enabled Word Document)
URLs	hxxp://shreeganesh-logistics.in.invoice-view-secure.com/download?file=inv2207
IOCs	Pending_Invoice_Challan_Details.docm, invoice-view-secure.com, 41.203.88.17, webmail-host-4.sharedhosting-cluster.com, failed SPF/DMARC authentication
Social Engineering	Urgency, financial pressure, business pretext, request to enable macros
Potential Impact	Opening the macro-enabled document and enabling macros could execute malicious code, leading to malware infection, credential theft, ransomware deployment, or unauthorized access to the organization's systems. Clicking the embedded link may redirect the recipient to a malicious website hosting malware or phishing content.
Recommended Action	Do not open the attachment or enable macros. Do not click the embedded link. Verify the invoice through a trusted communication channel before taking any action. Report the email to the Security team, quarantine the email, and block the associated domains if confirmed malicious.

IOCs

IOC Type	Indicator	Reason
Attachment	Pending_Invoice_Challan_Details.docm	Macro-enabled Word document (.docm) that can execute malicious code when macros are enabled.
Request	"Please enable editing/macros if prompted"	Encourages the recipient to enable macros, a common technique used to execute malware.

Domain	invoice-view-secure.com	Suspicious domain used in the embedded URL and unrelated to the sender's legitimate domain.
URL	hxxp://shreeganesh-logistics.in.invoice-view-secure.com/download?file=inv2207	Deceptive URL that places the company name as a subdomain while the actual domain is invoice-view-secure.com.
IP Address	41.203.88.17	External sending IP hosted on an unrelated shared hosting infrastructure rather than the sender's mail infrastructure.
Hostname	webmail-host-4.sharedhosting-cluster.com	Email originated from a generic shared hosting server, inconsistent with a legitimate corporate mail server.
Authentication	SPF: Fail, DKIM: None, DMARC: Fail	Email authentication failed, indicating the sender's identity could not be verified.